

Data Loss Prevention Policy

Comprehensive DLP policy aligned with Sri Lanka's Personal Data Protection Act (PDPA) No. 9 of 2022

Document ID	POL-DLP-001
Version	1.0 (template)
Classification	Internal
Owner	[Data Protection Officer / IT Security Manager]
Approved by	[Name, Title]
Effective date	[DD Month YYYY]
Next review	[DD Month YYYY — review at least annually]

Customization required

This template is a starting point published by the OpenDLP-LK community. Replace all bracketed placeholders, adapt the content to your organization's size, industry and risk profile, and obtain legal review before adoption. Aligned with Sri Lanka's Personal Data Protection Act (PDPA) No. 9 of 2022.

<https://opendlp-lk.github.io> • Licensed under MIT — free to use, adapt and redistribute.

1. Purpose

The purpose of this policy is to establish a framework for protecting sensitive and personal data held by [Organization Name] from unauthorized access, use, disclosure, alteration or loss, and to ensure compliance with Sri Lanka's Personal Data Protection Act (PDPA) No. 9 of 2022 and applicable contractual and regulatory obligations.

2. Scope

This policy applies to:

- All employees, contractors, interns, consultants and third parties who create, access, process, store or transmit data owned or controlled by [Organization Name].
- All information systems, networks, applications, endpoints, mobile devices, removable media and cloud services used for organizational data.
- All data classified as Internal, Confidential or Restricted under the Data Classification Framework, with particular emphasis on personal data as defined by the PDPA.

3. Definitions

Term	Definition
Personal data	Any information that can identify a data subject directly or indirectly, as defined in Section 56 of the PDPA (e.g. name, NIC number, contact details, location data, online identifiers).
Special categories of personal data	Personal data revealing racial or ethnic origin, political opinions, religious beliefs, health, biometric or genetic data, or data relating to offences, which require heightened protection.
Data controller	[Organization Name], which determines the purposes and means of processing personal data.
Data processor	A third party that processes personal data on behalf of the organization under a written agreement.
DLP	Data Loss Prevention — the tools, processes and controls used to detect and prevent unauthorized disclosure or exfiltration of sensitive data.
Data subject	An identified or identifiable natural person to whom personal data relates.

4. Policy Statements

4.1 Data Classification

All organizational data must be classified as Public, Internal, Confidential or Restricted in accordance with the Data Classification Framework. Data owners are responsible for assigning and reviewing classifications. DLP controls are enforced according to classification level.

4.2 Access Control

- Access to Confidential and Restricted data is granted on a need-to-know basis using role-based access control (RBAC).
- Access rights must be reviewed at least quarterly and revoked within 24 hours of role change or termination.
- Multi-factor authentication (MFA) is mandatory for all access to Restricted data and for all remote access.

4.3 Data in Transit

- Sensitive data transmitted over any network must be encrypted using TLS 1.2 or higher.
- Unencrypted protocols (FTP, Telnet, HTTP) must not be used to transfer Confidential or Restricted data.
- Email containing Restricted data must be encrypted or sent through the approved secure file transfer service.

4.4 Data at Rest

- Restricted data stored on servers, databases, laptops and mobile devices must be encrypted using AES-256 or equivalent.
- Full-disk encryption is mandatory on all portable endpoints.
- Encryption keys must be managed centrally and separated from the data they protect.

4.5 Removable Media

- Use of USB storage and external drives is prohibited by default and permitted only via documented exception approved by [IT Security Manager].
- Approved removable media must be encrypted and registered with IT.
- DLP endpoint agents must log and, where configured, block copying of Confidential or Restricted data to removable media.

4.6 Email and Messaging

- Outbound email is monitored by DLP content inspection for Sri Lankan data patterns (NIC numbers, passport numbers, phone numbers, bank account numbers) and organization-specific identifiers.
- Auto-forwarding of corporate email to external mailboxes is prohibited.
- Sensitive data must not be shared through personal email or unapproved messaging applications.

4.7 Cloud Services

- Only cloud services approved by [IT Department] may be used to store or process organizational data.
- Cloud storage of Restricted data requires encryption with organization-managed keys where feasible.
- Shadow IT discovery scans must be performed at least quarterly.

4.8 Mobile Devices and BYOD

- Corporate and BYOD devices accessing organizational data must be enrolled in the approved MDM/MAM solution.
- Devices must enforce screen lock, encryption and remote-wipe capability.
- Jailbroken or rooted devices are prohibited from accessing corporate resources.

4.9 Monitoring and Auditing

- DLP systems must log policy violations, and logs must be retained for at least [12] months.
- The DLP rule set must be reviewed at least quarterly and after significant business or regulatory change.
- An annual DLP program audit must be reported to [senior management / the board].

4.10 Incident Response

Suspected or confirmed data loss incidents must be reported immediately to [security@organization.lk] and handled under the Data Breach Incident Response Plan, including notification to the Data Protection Authority within the timeframe required by PDPA Section 23 where applicable.

5. PDPA Compliance Mapping

PDPA obligation	Reference	Supporting controls in this policy
Lawful processing of personal data	Part I	Data inventory, purpose registration, access on need-to-know basis (4.1, 4.2)
Purpose limitation and data minimization	Part I	Classification-driven handling rules; collection limited to defined purposes (4.1)
Accuracy and retention	Part I	Data owner reviews; retention schedule; secure disposal (4.1, 4.9)
Security safeguards	Part I	Encryption in transit/at rest, MFA, endpoint DLP, MDM (4.3–4.8)
Personal data breach notification	Section 23	Incident response procedures and DPA notification workflow (4.10)
Data subject rights	Part II	Access, rectification and erasure request handling procedure [reference SOP]

6. Roles and Responsibilities

Role	Responsibilities
Board / Senior management	Approve policy; provide resources; review annual DLP program reports.
Data Protection Officer (DPO)	Own the policy; liaise with the Data Protection Authority; maintain the data inventory; oversee breach notification.
IT Security / DLP administrator	Configure and operate DLP tooling; tune rules; triage alerts; produce metrics.
Data owners (business unit heads)	Classify data; approve access; review entitlements quarterly.
All personnel	Handle data per classification rules; complete training; report incidents immediately.

7. Enforcement

Violations of this policy may result in one or more of the following, proportionate to severity and intent:

- Verbal or written warning and mandatory retraining.
- Suspension of system access privileges.
- Disciplinary action up to and including termination of employment or contract.
- Referral for civil or criminal action where required under the PDPA or other applicable law.

8. Review and Maintenance

This policy must be reviewed at least annually, and additionally upon significant changes to business operations, technology, or the regulatory environment. Changes require approval by [approving authority].

9. Revision History

Version	Date	Author	Summary of changes
0.1	[date]	[name]	Initial draft from OpenDLP-LK template
1.0	[date]	[name]	Approved release